

Universidad Tecnológica Nacional

Tecnicatura Universitaria en Programación (a distancia)

Asignatura: Base de Datos

Trabajo Práctico: Fundamentos y Desafíos Emergentes en la Seguridad de Bases de Datos

Módulo 8

Alumno: *Damian Eduardo Tristant*

Legajo: *(Matricula 100639)*

Fecha: *Noviembre de 2025*

1.

El cifrado homomórfico es una tecnología de seguridad que permite realizar operaciones sobre datos sin necesidad de descifrarlos previamente. Es decir, los datos permanecen cifrados durante todo el proceso de cálculo, y solo quien tenga la clave puede ver el resultado final en texto claro. Esto lo convierte en una herramienta clave para proteger la privacidad de la información mientras está en uso, algo que los métodos de cifrado tradicionales no permiten.

El principio fundamental del cifrado homomórfico se basa en que ciertas operaciones matemáticas (como suma o multiplicación) pueden aplicarse directamente sobre los datos cifrados, y al descifrar el resultado se obtiene el mismo valor que si se hubieran realizado las operaciones sobre los datos originales.

La gran diferencia con los cifrados tradicionales, como el cifrado “en reposo” (cuando los datos están guardados) o “en tránsito” (cuando viajan por la red), es que esos métodos protegen los datos solo cuando no se están procesando. En cambio, el cifrado homomórfico protege los datos mientras se procesan en la memoria, evitando que queden expuestos incluso durante operaciones o análisis.

Ventajas principales:

Máxima privacidad de los datos: permite procesar información sensible (como datos personales o financieros) sin que el sistema que realiza los cálculos pueda ver su contenido.

Cumplimiento normativo: facilita el cumplimiento de leyes de protección de datos (como la Ley 25.326 o el RGPD) al evitar la exposición de información confidencial durante su procesamiento.

Desafíos o limitaciones

Alto costo computacional: los algoritmos homomórficos requieren mucha potencia de cálculo, lo que los hace más lentos que los métodos tradicionales.

Complejidad de implementación: todavía es una tecnología en desarrollo, y aplicarla en sistemas de bases de datos a gran escala puede ser complicado y costoso.

Ejemplos de aplicación:

Servicios en la nube: las empresas pueden procesar datos cifrados sin acceder a su contenido, protegiendo la privacidad de los clientes mientras utilizan plataformas cloud.

Análisis de datos médicos o financieros: se pueden realizar cálculos o estadísticas sobre información sensible sin revelar los datos personales de los pacientes o usuarios.

2.

La auditoría y el monitoreo en bases de datos son herramientas fundamentales para mantener la seguridad y la integridad de la información. Su principal propósito es detectar y registrar actividades sospechosas o no autorizadas, y así poder prevenir ataques, errores humanos o violaciones a las políticas internas de seguridad.

El propósito principal de estas prácticas es garantizar que cualquier acción realizada dentro de la base de datos quede registrada. Esto incluye quién accede, qué cambios realiza, cuándo lo hace y desde qué ubicación. De esa forma se obtiene una trazabilidad completa que permite identificar comportamientos anómalos o investigar incidentes de seguridad.

Tres tipos de actividades que deben ser monitoreadas:

Inicio de sesión y accesos: registrar cada conexión a la base de datos ayuda a detectar intentos de acceso no autorizados o conexiones fuera de horario.

Cambios en la estructura o esquema: modificar tablas, vistas o procedimientos almacenados puede afectar la seguridad; por eso es importante auditar cualquier alteración.

Ejecución de consultas y modificaciones de datos: supervisar consultas que leen o actualizan información sensible permite detectar posibles fugas o manipulación indebida de datos.

Las herramientas SIEM (Security Information and Event Management) complementan la auditoría porque recopilan y analizan los registros generados por múltiples sistemas (incluyendo bases de datos, redes y aplicaciones). Gracias a sus algoritmos de correlación, pueden identificar patrones sospechosos en tiempo real, emitir alertas automáticas y generar reportes detallados que ayudan a los administradores a reaccionar rápidamente ante un posible incidente.

Además, la auditoría y el monitoreo son esenciales para cumplir con las leyes de protección de datos, como la Ley 25.326 en Argentina o el Reglamento General de Protección de Datos (RGPD) en la Unión Europea. Estas normativas exigen que las organizaciones tomen medidas activas para proteger la información personal de los usuarios, y contar con registros de auditoría es una forma de demostrar que se aplican políticas de seguridad adecuadas.

3.

Las estrategias de respaldo y recuperación son fundamentales para garantizar la disponibilidad y seguridad de los datos. En caso de una falla de hardware, un ataque informático o un error humano, los respaldos permiten restaurar la información y continuar con las operaciones del sistema sin grandes pérdidas. En otras palabras, son la base de la resiliencia de una base de datos.

La importancia principal de estas estrategias radica en que aseguran que los datos críticos estén protegidos y puedan recuperarse en el menor tiempo posible. Sin un buen plan de respaldo, una organización corre el riesgo de perder información valiosa, sufrir interrupciones operativas y hasta daños reputacionales o legales.

Tipos de respaldo:

Respaldo completo: consiste en una copia total de toda la base de datos. Se usa generalmente como punto de partida o cuando se necesita una versión completa para restaurar todo el sistema. Su ventaja es que simplifica la recuperación, pero ocupa más espacio y tiempo.

Respaldo diferencial: guarda los cambios ocurridos desde el último respaldo completo. Permite una recuperación más rápida que hacer varios incrementales, y ahorra espacio respecto a los completos.

Respaldo incremental: registra solo los cambios realizados desde el último respaldo de cualquier tipo (completo, diferencial o incremental). Es más eficiente en espacio y tiempo, pero su recuperación puede requerir aplicar varios respaldos sucesivos.

Respaldo de registro de transacciones: almacena todas las transacciones realizadas en la base de datos. Es crucial para realizar una recuperación puntual, es decir, volver la base al estado exacto en que estaba antes de un fallo o error.

Una buena práctica es aplicar la Regla 3-2-1 de respaldos:

3 copias de los datos: una principal y dos de respaldo.

2 tipos de almacenamiento diferentes: por ejemplo, disco local y dispositivo externo o nube.

1 copia fuera del sitio: mantener una copia en un lugar físico distinto o en la nube evita pérdidas ante desastres locales (como incendios o robos).

Esta regla es vital porque garantiza redundancia, diversidad de medios y protección ante eventos imprevistos.

Además, las estrategias de respaldo deben considerar el RPO (Objetivo de Punto de Recuperación) y el RTO (Objetivo de Tiempo de Recuperación).

El RPO define cuánta información se puede perder sin afectar gravemente a la organización (por ejemplo, perder los datos de las últimas 2 horas).

El RTO indica cuánto tiempo puede tardar el sistema en volver a funcionar después de un fallo.

Ambos parámetros permiten diseñar políticas de respaldo realistas y alineadas con las necesidades del negocio.

Por último, es fundamental probar y documentar periódicamente los procedimientos de recuperación, ya que no sirve de nada tener copias si no verifica que realmente funcionan. Las pruebas garantizan que los responsables sepan cómo actuar ante una emergencia y reducen el tiempo de inactividad.

Bibliografía:

BM Research. (2021, abril 8). Fully homomorphic encryption is more real than you think. IBM.

<https://www.ibm.com/blogs/research/2021/04/08/fully-homomorphic-encryption-is-more-real-than-you-think/>

Microsoft Research. (s.f.). Homomorphic Encryption. Microsoft.

<https://www.microsoft.com/en-us/research/project/homomorphic-encryption/>

OpenFHE. (s.f.). OpenFHE Project: Open-Source Fully Homomorphic Encryption Library.

<https://www.openfhe.org/>

Instituto Nacional de Ciberseguridad (INCIBE). (s.f.). Seguridad en bases de datos.

<https://www.incibe.es/>

Oracle Corporation. (s.f.). Auditing and Security in Oracle Database. Oracle Documentation.

<https://docs.oracle.com/en/database/oracle/oracle-database/index.html>

Microsoft. (s.f.). SQL Server Audit (Database Engine). Microsoft Learn.

<https://learn.microsoft.com/es-es/sql/relational-databases/security/auditing/sql-server-audit-database-engine>

Microsoft. (s.f.). Estrategias de respaldo y restauración en SQL Server. Microsoft Learn.

<https://learn.microsoft.com/es-es/sql/relational-databases/backup-restore/backup-overview-sql-server>

PostgreSQL Global Development Group. (s.f.). Documentation: Security and Backup.

<https://www.postgresql.org/docs/>

Ley 25.326. (2000). Protección de los Datos Personales. República Argentina.

<https://www.argentina.gob.ar/normativa/nacional/ley-25326-6295>